보안·네트워크 구축 가이드

대상: 고객사 보안팀·네트워크팀 · 제품 기준: 1.0.8 · 현행화: 2026-10-12

1. 데이터가 어디로 가는가

WorkNexus는 고객 서버에 설치하는 제품입니다. 다만 **접속 방식에 따라 웹 트래픽 경로가 달라지므로** 아래처럼 구분해서 설명합니다. "외부 전송 없음"처럼 한 문장으로 단정하지 않습니다.

데이터	저장·처리 위치	고정 도메인(`회사약칭.calamus.ai.kr`) 사용 시	폐쇄망 모드
사원·근태·채팅·게시판·예약 DB	고객 서버(SQLite)에만 저장	저장은 고객 서버. 화면에 보내는 웹 요청·WebSocket은 Cloudflare 터널을 거침	사내망 안에서만 오감
음성·카메라·화면공유 미디어	고객 서버의 LiveKit SFU가 중계(저장 안 함)	미디어는 Cloudflare를 거치지 않고 UDP/TCP로 서버에 직접 연결. 연결 신호(WSS)는 터널 경유	사내망 안에서만 오감
로그인·비밀번호	고객 서버에서 검증. 비밀번호는 해시로 저장	로그인 요청이 터널을 거침(HTTPS)	사내망 안에서만 오감
라이선스	서명된 파일을 서버가 오프라인으로 검증	정기적인 외부 확인 없음	동일

정리하면 다음과 같습니다.

- **음성·영상 미디어와 DB는 사내 서버에만 있습니다.** 공급자나 Cloudflare에 저장되지 않습니다.
- **고정 도메인을 쓰면 웹 접속 경로는 Cloudflare를 거칩니다.** HTTPS는 Cloudflare 엣지에서 한 번 종료된 뒤 터널로 고객 서버에 전달됩니다. 웹 화면에 오가는 내용(로그인, 채팅, 게시판 글 등)이 Cloudflare 네트워크를 통과한다는 뜻입니다. 이 경로가 허용되지 않으면 폐쇄망 모드나 Split DNS(아래 2장)를 사용합니다.
- **폐쇄망 모드에서는 서버가 외부로 연결하지 않습니다.** 터널을 끄고 사내 IP·사내 도메인으로만 접속합니다. 라이선스는 파일로 등록하고, 업데이트 파일은 담당자가 내려받아 반입합니다.
- Windows: 관리자 센터 → **외부 접속 및 터널 설정** → **외부 터널 차단(폐쇄망 전환)**
- Linux: 설치할 때 `sudo ./install.sh --no-tunnel`
- 웹 화면의 글꼴은 앱에 내장되어 있어 인터넷 글꼴 서버(Google Fonts 등)에 접속하지 않습니다(1.0.7부터).
- LiveKit의 `use_external_ip` 는 기본값이 꺼짐입니다. 사외 영상 연결을 위해 켜면 서버가 자기 공인 IP를 알아내려고 공용 STUN 서버에 질의합니다.

2. 권장 배치 모델

1. **사내 전용(폐쇄망)**: 내부 사용자만 접속합니다. 가장 단순하고 통제가 쉽습니다.
2. **사내 서버 + VPN**: 재택·출장자는 회사 VPN으로 접속합니다. 현재 구현만으로 운영할 수 있습니다.
3. **DMZ 미디어/접속 계층 + 내부 업무·DB 계층 분리**: 고보안·대규모 고객에게 권장하는 구조입니다. 별도 네트워크 설계와 배포 구성이 필요합니다.
4. **고정 도메인 인터넷 접속**: `회사약칭.calamus.ai.kr`로 편리하게 접속합니다. 별도 접속 제한을 두지 않으면 인터넷에서 로그인 화면까지 접근할 수 있으므로 3장의 통제와 접근 제한(예: Cloudflare Access, 사내 IP 제한)을 함께 검토합니다.



온프레미스 운영 소개 화면

> 위 이미지는 제품 소개용 개념 화면입니다. 실제 방화벽 허용 범위와 서버 배치는 고객 보안정책에 따라 별도 승인해야 합니다.

고정 도메인을 사내에서 열 때도 기본 DNS가 공인 주소를 가리키면 Cloudflare를 거쳐 돌아옵니다. 내부 DNS가 같은 도메인을 내부 서버/프록시로 해석하는 **Split DNS**를 구성하면 사내 사용자는 Cloudflare를 거치지 않고 내부 경로로 직접 접속합니다.

구성요소

- 사용자 브라우저
- WorkNexus 웹/API 서버와 SQLite DB
- LiveKit SFU(음성·영상·화면공유 중계)
- Cloudflare named tunnel(고정 도메인 사용 시, 웹·WSS)
- 선택적 TURN(설정한 경우)
- 백업 저장소

DB와 라이선스 비밀은 내부 신뢰구역에 두고 외부에 직접 공개하지 않습니다. DMZ로 분리할 때는 터널 커넥터와 TURN/SFU 노출 계층을 DMZ에 두고, 애플리케이션·DB 접근은 필요한 방향과 포트만 허용합니다.

3. 포트 검토표

설치판마다 미디어 UDP 범위가 다릅니다. 설치한 판에 맞는 범위만 엽니다.

용도	포트	Windows 설치판	Linux 도커판	권장 허용 범위
웹 앱(사내 직접 접속·진단)	TCP 3001	사용	사용	사내망만. 인터넷 공개 금지
LiveKit 신호	TCP 7880	사용	사용	사내망·프록시
미디어 예비 경로(ICE/TCP)	TCP 7881	사용	사용	미디어 사용자 대역
미디어(RTP)	**UDP**	**50000~50200** (201개)	**50000~50300** (301개)	미디어 사용자 대역
TURN	UDP 3478	설정한 경우만	사용	외부·엄격 NAT 사용자가 있을 때
HTTPS	TCP 443	고정 도메인(터널)·사내 프록시	동일	서버에서 Cloudflare 방향 아웃바운드

- Windows는 서버가 만드는 LiveKit 설정(`livekit.runtime.yaml`)의 고정값, Linux는 `deploy/docker.env`의 `LIVEKIT_RTC_UDP_PORT_START/END` 기본값입니다. 범위를 바꾸면 방화벽 표도 같이 바꿉니다.
- 고정 도메인 터널은 **서버에서 바깥으로 나가는 연결**(443)만 씁니다. 인터넷에서 서버로 들어오는 포트를 열 필요가 없습니다. 사외 사용자의 영상·음성까지 필요할 때만 미디어 포트의 포트포워딩 또는 TURN을 설계합니다.
- Docker가 공개한 포트는 UFW 규칙을 거치지 않습니다. 상위 방화벽, `DOCKER-USER` 체인, 사설 인터페이스 바인딩으로 제한합니다.

4. 인증·계정·세션 (현재 동작)

보안 검토에서 자주 묻는 항목입니다. 현재 버전의 실제 동작과 아직 지원하지 않는 기능을 그대로 적습니다.

항목	현재 동작(1.0.8)
최초 관리자	공용 기본 관리자 계정 없음. 설치 때 만들어지는 일회용 등록 토큰으로 생성
신규 사원 초기 비밀번호	기본은 `1234`. 관리자가 **초기 비밀번호 무작위 발급**을 켜면 10자리 무작위 값을 만들어 등록 직후 관리자 화면에 **한 번만** 보여 줌(서버에는 해시만 저장). 어느 쪽이든 **최초 로그인 때 새 비밀번호를 정해야 하며, 바꾸기 전에는 서버가 비밀번호 변경·로그아웃 외의 API와 오피스 입장을 거부**함
비밀번호 초기화	관리자가 사원 정보 수정 화면에서 초기화. 정책에 따라 `1234` 또는 무작위 값을 새로 발급하고, 그 사원의 기존 로그인은 즉시 끊김
비밀번호 규칙	8자 이상. 해시로 저장
로그인 실패 제한	같은 계정·접속지에서 15분 동안 10회 실패하면 일시 차단
세션	로그인 후 최대 **24시간** 유지. 관리자가 **미사용 자동 로그아웃**(30분·1·2·4·8시간)을 켜면 키보드·마우스·터치 입력이 없고 회의·통화·화면공유 중도 아닐 때 그 시간이 지나면 서버가 세션을 끝냄(1분 전 경고, 근태는 퇴근이 아닌 **자리 비움**으로 기록). 기본은 꺼짐. 로그아웃·퇴근 시 즉시 종료
같은 계정 동시 로그인	새 로그인이 들어오면 이전 연결 정리
로그인 전 사원 목록	기본은 로그인 화면에 사원 카드(이름·직급·부서·이메일·접속 여부)를 보여 주고 카드를 골라 로그인. 관리자가 **로그인 전 사원 목록 숨기기**를 켜면 목록을 내려주지 않고 **이메일 로그인만** 허용. 연락처·주소 등 다른 개인정보는 어느 경우에도 보이지 않음
관리자 작업 기록	감사 로그 기록
방 회의 외부 참석 링크 (1.0.8)	회의마다 무작위 코드 링크. **회의 시작 30분 전~종료 30분 후**만 유효. 입장 때 이름·소속·동의 필요. 받은 입장권은 그 방 회의 미디어·회의 채팅에만 쓰이고 다른 사내 API는 거부. 재발급·끄기·내보내기 즉시 연결 해제. 감사 로그 기록. 틀린 코드에는 회의가 있는지도 알려 주지 않음

로그인 전 사원 목록 관련 권고: 고정 도메인을 인터넷에 공개하면 누구나 로그인 화면에서 조직 구성을 볼 수 있습니다. 공개 구성에서는 관리자 센터 → 사원 및 인사(HR) 관리 → **로그인·초기 비밀번호 보안 정책**에서 **로그인 전 사원 목록 숨기기**를 켜십시오. 필요하면 Cloudflare Access(이메일 인증) 같은 앞단 접근 제한이나 폐쇄망·VPN 구성을 함께 사용합니다.

아직 지원하지 않는 기능(로드맵)

- SSO(SAML·OIDC), LDAP/Active Directory 연동
- 2단계 인증(OTP 등)
- 최대 세션 시간(24시간) 변경

현재는 위 기능이 필요한 고객에게 Cloudflare Access나 VPN 같은 앞단 인증으로 보완하도록 안내합니다.

5. 기타 보안 통제

- 고정 도메인은 HTTPS로만 제공. 사내 HTTP(3001)는 사내망 접속·진단용
- 라이선스·건물 구성·도메인은 전자서명으로 검증
- 서버마다 LiveKit key/secret을 설치 때 새로 생성(패키지 공용 키 없음)
- 터널 토큰·LiveKit secret·백업은 접근 권한을 최소화
- 고객 계정은 공급자용 건물 스튜디오에 접근할 수 없음
- 음성·영상·화면공유는 모두 LiveKit SFU를 거치며 사용자 PC끼리 직접 연결하지 않음. 방마다 LiveKit 방이 분리됨
- 정기 백업·복구 훈련, 퇴사자 즉시 비활성화, 공유 계정 금지
- **외부 참석**(타운홀 게스트, 1.0.8부터 방 회의 외부 참석 링크)은 인터넷에서 들어오는 사람이 대상입니다. 외부 참석자는 고객 전용 터널 주소(`회사약칭.calamus.ai.kr`)로 **링크만 눌러** 들어옵니다(별도 VPN·계정 불필요). 고객이 직접 그 주소 앞에 Cloudflare Access 같은 추가 인증을 걸었거나 VPN 사용자만 접속하게 막아 둔 경우에만 외부 참석자(타운홀 게스트 포함)도 막히며, 이때는 외부 참석용 예외 설정이 필요합니다. 외부 참석자의 영상·음성도 고객 서버 LiveKit을 거치므로 외부 회선에서 미디어(UDP 또는 TCP 7881·TURN) 연결을 검수합니다.

6. 외부 접속 시험

웹 접속 성공과 영상·음성(WebRTC) 연결 성공은 별개입니다. 외부망을 허용한다면 서로 다른 두 인터넷 회선에서 로그인, 마이크, 카메라, 화면+오디오 공유, 재연결을 확인합니다. UDP가 차단되는 조직은 ICE/TCP(7881) 또는 TURN 경로를 설계해야 합니다.

7. 서버 위치 결정

- 외부 접속이 필요 없고 보안이 최우선이면 내부망(폐쇄망 모드).
- 재택 사용자가 이미 회사 VPN을 쓰면 내부망 + VPN.
- 인터넷 사용자와 내부 업무 데이터를 분리해야 하면 DMZ 구조.

- 별도 보안망 없이 고정 도메인을 공개하면 쓰기는 편하지만 인터넷에 노출됩니다. 앞단 접근 제한, 강한 비밀번호 정책, 모니터링을 함께 적용합니다.

더 자세한 사내망 HTTPS·인증서 구성은 문서센터의 **사내망 HTTPS 구축 가이드**를 함께 검토합니다.
